

Change record — P6 Network segmentation, remote-access VPN and enterprise Wi-Fi

Written to the standard Halden uses for every change (feeds the change log and the P10 governance dashboard). This is the highest-risk change in the portfolio: it can break sign-in, file access and Group Policy at once, and a mistake in the firewall can lock IT out of the firewall itself. That is why the backout plan is longer than the implementation plan. In a small company the same person often proposes and approves; that separation is documented honestly rather than pretended.

Field	Value
Change ID	CHG-2026-006
Title	P6 — Network segmentation (six zones), remove exposed RDP, remote-access VPN with MFA, WireGuard site-to-site, 802.1X Wi-Fi
Raised by	IT (Muhammad Ibrahim Akmal)
Approved by	Managing Director (<i>business owner of the fictional Halden; see the note on the lab</i>)
Additional approvals required	Operations Director (IoT/scan-to-folder exception), any department requesting a VPN exception
Date raised	2026-10-02
Planned implementation	Phases 0–6, one short maintenance window each, outside working hours
Category / risk	Network — High risk . Widely scoped: touches addressing, authentication, file access and remote access
Affected services	Sign-in, DNS, DHCP, file shares, Group Policy, service desk portal, warehouse connectivity, guest Wi-Fi, remote access
Affected systems	FW01, FW02, DC01, DC02, FS01 (NPS), CA01, LNX01, OPS01, BKP01, HOST01, WS01, WS02, the lab access point if present

1. Description of the change

Replace the flat office network with six firewall-enforced zones (servers, warehouse, staff, management, guest, devices) plus a VPN pool, with **deny by default** between them and a documented rule matrix giving every exception an owner and a reason. Remove the internet-exposed remote desktop forward and replace it with a remote-access VPN authenticated by NPS/RADIUS against an AD group, with a second factor. Join the warehouse firewall to HQ with a WireGuard site-to-site tunnel so site 2 clients authenticate and reach files as if on site. Replace the shared Wi-Fi password with certificate-based 802.1X (EAP-TLS) using an internal certificate authority, and isolate guest Wi-Fi. Add DNS and egress control so clients resolve names only through the domain. Prove all of it with an automated segmentation test suite rather than asserting it.

2. Reason for the change

Guests, CCTV, printers, scanners, laptops and servers currently share one subnet, so anything that reaches the network reaches everything on it; the Wi-Fi password has been unchanged for three years and is written on the break-room wall; and remote staff reach the file server through an exposed remote desktop port, which is one of the most common ransomware entry points. The change limits how far a single compromised device can spread, removes the exposed service, and replaces a shared password with identity-based access.

3. Impact and risk

Area	Impact	Mitigation
Sign-in and Group Policy	A missing AD port in the rule set breaks logon or policy processing and looks like a DNS fault	Complete AD port list (including the RPC range) reviewed before the change; <code>gpupdate</code> and <code>gpresult</code> checked after every rule change; deny log watched
Addressing	Clients on a new VLAN need a relay and a new scope; a mistake leaves a zone with no addresses	The relay and the new scope are tested zone by zone; a client lease is verified before moving to the next zone
File access	A missing rule leaves a department without its share	The file-share flow is an explicit matrix entry, tested as part of the suite
Remote access	Users who rely on remote desktop must change how they connect	Staff guide issued in advance; VPN tested with a real user before the old forward is removed
Warehouse connectivity	Site 2 depends on the tunnel	Tunnel verified with a real client, site selection checked with <code>nltest /dsgetsite</code> , and a mapped drive opened
Guests and visitors	Guest Wi-Fi changes to vouchers	Notice displayed at reception; reception staff briefed on issuing vouchers
Wi-Fi	Personal devices can no longer join the corporate SSID	Communicated in advance; certificate autoenrollment verified on domain devices
IT losing access to the firewall	Total loss of management for the whole network	Anti-lockout rule kept, console access open during every change, configuration exported before each change
Devices	A device in the wrong zone may not work as expected	Zone assignment documented; IoT scan-to-folder approved by Operations
Access creep	"Temporary" allow rules that are never removed	Numbered rules with an owner; quarterly rule review

4. Implementation plan (phases)

Phase	Work	Window	Verification
0	Design, rule matrix, IP plan, test plan, this change record	2026-10-02	Reviewed against the plan; matrix has an owner per row

Phase	Work	Window	Verification
1	VLANs, interfaces, DHCP relay, aliases, rules on FW01; new Windows scopes; AD subnets	Out of hours	Interfaces up; each rule shows its matrix number; a client leases an address in its new zone
2	DNS and egress filtering	Out of hours	External resolver times out from a client; resolution through the DCs works; redirect logged
3	Remove the RDP forward; VPN with RADIUS and MFA; access process	Out of hours	Lab WAN shows the port filtered; NPS 6272/6273; a second factor prompt; management zone unreachable over the tunnel
4	WireGuard site-to-site and its rules	Out of hours	Handshake on both peers; warehouse client leases, authenticates and maps a drive
5	CA01, certificate templates, autoenrollment, NPS EAP-TLS policy, wireless GPO, PSK retirement	Out of hours	Device certificate present; <code>eapol_test</code> result; guest client reaches nothing internal
6	Segmentation suite, isolation tests, config backup, final diagrams	Same evening	The results CSVs; a sanitised config summary committed; diagrams current

5. Test plan (acceptance)

1. The segmentation suite reports every expected-allowed path open and every expected-denied path blocked, from a host in each zone.

1. A guest device reaches the internet and no company system.
2. An IoT device reaches the scan-to-folder share and nothing else internal.
3. Remote desktop from the lab WAN is filtered, not open.
4. A user not in the VPN group is rejected (NPS event 6273 with a reason code).
5. A user in the group connects with a second factor and reaches the file server but **not** the management zone.

1. A domain device connects to the corporate Wi-Fi by certificate; a device without one is rejected.
2. A warehouse client gets a lease across the tunnel, authenticates, maps a drive and reports `WAREHOUSE` from `nltest /dsgetsite`.

1. Re-running an apply script changes nothing (idempotent).

6. Backout plan

Every phase is snapshotted before it runs (`snap-p6-ph<N>-before`). In addition, and more importantly for this change:

1. **The firewall configuration is exported before every firewall change**

(`scripts/12-Export-ConfigBackup.sh`). Restoring that export returns the entire rule set to its previous state in minutes — this is the primary backout, not the snapshot.

- 1. **Console access to FW01 and FW02 is kept open** for the whole window, and the anti-lockout rule is never removed. If management access is lost, restore from the console.
- 1. **VLAN tags are reverted** on the hypervisor (`Set-VMNetworkAdapterVlan -Access/-Untagged`), which returns a host to its previous network.
- 1. **The RDP forward is not restored** as part of any backout. That port forward is the problem this change removes; if remote access must be restored, restore the VPN.
- 1. **Order of backout** if a phase fails: revert that phase first (rule/scope/interface), confirm sign-in and file access, then investigate. Do not revert a domain controller snapshot unless there is no alternative — fix DC problems forward.
- 1. **After any backout**, re-run the relevant part of the test suite and record what was reverted and why in this record.

7. Comms plan

Audience	Message	When
All staff	What changes (Wi-Fi, home working), what they must do, who to call	At least 3 days before
Reception	How to issue guest vouchers; never give out corporate Wi-Fi details	Before the guest change
Warehouse	Site 2 tunnel and its window	Before Phase 4
Department heads	The access policy and how exceptions are requested	With the exec brief
IT / service desk	Runbooks: apply a rule change, add a device to a zone, on-board a remote user, firewall backup/restore	Before Phase 1

8. Post-implementation review

To be completed when the last phase is verified: actual completion date, the acceptance test results with their evidence files, anything that went wrong, any exception still outstanding, and whether any phase overran. Results are recorded in `projects/p06-network-segmentation/README.md` , with every number pointing at a file in `evidence/` . ****Nothing is recorded here as a result until it has been measured in the lab.****

Note: this is a home-lab change record for a fictional company (Halden Distribution Ltd.). The technical content, scripts and test method are real; the business approval line represents the lab owner's decision, not a real customer sign-off.